

Security Risk Assessment: Network Hardening and Access Control

Simulated Case Study

Risk Assessment Summary

A simulated post-breach security assessment of a social media organization identified four weaknesses that could increase the likelihood or impact of future unauthorized access: employees share passwords, the database administrative account retains a default password, firewall traffic-filtering rules are not configured, and multi-factor authentication (MFA) is not enforced.

The organization has already experienced a breach involving customer personal information, including names and addresses. These weaknesses leave the organization exposed to future unauthorized access and should be addressed through stronger identity controls, access restrictions, and network security practices.

Identified Vulnerabilities

- **Shared employee passwords.** Credential sharing reduces individual accountability and increases the chance that unauthorized users can obtain access through another person's credentials.
- **Default database administrator password.** Leaving a privileged account on a default credential creates unnecessary exposure and could allow unauthorized access to sensitive customer data if the credential is known or guessed.
- **Missing firewall filtering rules.** Without an established filtering policy, the organization lacks adequate control over which inbound and outbound network connections should be permitted or denied.
- **No multi-factor authentication.** If authentication relies only on passwords, a stolen, shared, or successfully guessed password may be sufficient to gain access to an account.

Recommended Hardening Controls

Identity and authentication controls. Replace the default database administrator password immediately and replace shared credentials with individual user accounts. Privileged and user accounts should use long, unique passwords, supported by an approved password manager where appropriate. MFA should be required, beginning with administrative, privileged, and remote-access accounts, so that a password alone is not sufficient to authenticate.

Firewall policy and traffic filtering. Configure the firewall so only traffic needed for legitimate business operations is allowed through. Unnecessary ports and connections should be blocked, with tighter controls around systems that store or process sensitive customer information.

Least privilege and network access controls. Access to databases, administrative interfaces, and other sensitive resources should be limited to the users, roles, and systems that require it. Role-based access controls and access-control lists should be used where appropriate, and privileged access should be separated from ordinary day-to-day user access.

Implementation and Maintenance

Immediate actions: Replace the default database administrator credential, rotate any credentials known to have been shared, assign individual accounts, enable MFA for privileged access, and establish baseline firewall rules that permit only required traffic.

Ongoing controls: MFA and access restrictions should remain continuously enforced. Firewall rules should be reviewed after significant network or service changes, after relevant security events, and on a defined maintenance schedule. User permissions should be reviewed when employees change roles or leave the organization and periodically to confirm continued need.

Authentication and firewall activity should also be logged and monitored so suspicious access attempts or unexpected traffic can be investigated. Shared or compromised credentials should be replaced as soon as they are identified.